

Fly GACA — PDPL Personal Data Breach Notification Procedure

SECTION 02-legal TYPE legal STATUS **draft** OWNER Founder / DPO UPDATED 2026-06-14

Document: [pdpl-breach-notification-procedure-draft-2026-06-14.md](#) **Version:** Draft 1.0 — 2026-06-14 **Status:** DRAFT — requires review by a qualified Saudi-licensed lawyer before use. **Purpose:** Internal operational procedure for identifying, containing, assessing, and notifying personal data security incidents under PDPL Art. 20 and SDAIA Implementing Regulations. **Owner:** Founder / DPO (Adel Yahya A. Madkhali) **Contact:** privacy@flygaca.com | security@flygaca.com

DRAFT — requires review by a qualified Saudi-licensed lawyer before use.

This document is a working draft prepared by an AI assistant for founder review. It is NOT legal advice. It must be reviewed by a Saudi-licensed lawyer (with PDPL expertise) before operational reliance.

Key review points: (1) Confirm the exact threshold for SDAIA notification under PDPL Art. 20 and SDAIA Implementing Regulations — in particular, whether the threshold is "likely to cause serious harm" and whether this is correctly characterised in Section 4 below; (2) Confirm the current SDAIA notification channel, portal, or reporting form; (3) Confirm whether data-subject notification is required under PDPL and, if so, in what circumstances and timeframe; (4) Whether this procedure is adequate as a standalone document or needs to be integrated into the ISP (04-compliance-ksa/information-security-policy.docx); (5) Confirm position under SDAIA Regulations re: breach registers and documentation requirements.

1. Purpose

This Procedure establishes the steps Fly GACA will follow when a personal data security incident ("Breach") is discovered. It is designed to ensure:

- Rapid detection, containment, and recovery
- Compliance with the 72-hour SDAIA notification obligation under PDPL Art. 20
- Timely notification to affected data subjects where required
- Documentation and learning to prevent recurrence

This Procedure applies to all Fly GACA staff, contractors, and third-party service providers who handle personal data.

2. Definitions

"Personal Data" means any data that leads to identifying a specific individual or makes it possible to identify them, as defined in the PDPL.

"Security Incident" means any event that results or may result in the compromise of personal data — including unauthorised access, disclosure, alteration, or destruction of personal data, whether intentional or accidental.

"Notifiable Breach" means a Security Incident that is likely to cause serious harm to any data subject, requiring notification to SDAIA under PDPL Art. 20.

"DPO" (Data Protection Officer / Contact): For Fly GACA at this stage, the founder (Adel Yahya A. Madkhali) acts as the responsible officer. Contact: privacy@flygaca.com.

"Incident Response Team" (IRT): At current scale, this is the founder plus any engaged technical contractors or the cybersecurity support contact. [To be expanded on entity formation and team growth.]

3. Incident Detection and Initial Response

3.1 Sources of Detection

Incidents may be detected through:

- Automated alerts from Firebase Security Rules violations, unusual authentication activity, or Cloudflare security monitoring
- Reports from users (via support@flygaca.com or security@flygaca.com)
- Reports from third-party sub-processors (Google Firebase, Cloudflare, Moyasar)
- Reports from security researchers (via security@flygaca.com — see [SECURITY.md](#))
- Internal discovery during routine system checks

3.2 Immediate Steps on Discovery

When a suspected Security Incident is identified, the discoverer must:

Step 1 — Report immediately. Contact the DPO (founder) by the fastest available means: security@flygaca.com or direct message. Do not delay to investigate independently.

Step 2 — Preserve evidence. Do not delete logs, alerts, or system records. Preserve all available technical evidence relevant to the incident.

Step 3 — Initial containment. Take immediate, proportionate steps to stop ongoing harm — for example, disabling a compromised access credential, revoking an exposed API key, or temporarily suspending access to an affected data store — without destroying evidence.

Step 4 — Record the time of discovery. The 72-hour SDAIA notification clock starts from the moment Fly GACA becomes aware of a Notifiable Breach.

4. Assessment — Is This a Notifiable Breach?

4.1 Threshold

Under PDPL Art. 20, a Notifiable Breach is one that is **likely to cause serious harm** to data subjects. SDAIA Implementing Regulations may specify additional criteria. [Counsel: please confirm the current regulatory threshold and any SDAIA guidance issued.]

4.2 Severity Assessment Matrix

The DPO will assess the incident against the following factors:

Factor	Low	Medium	High — Likely Notifiable
Data sensitivity	Technical/usage data only	Account data (email, name)	GACA licence numbers, exam records, payment-linked data
Number of data subjects affected	< 10	10–100	> 100
Nature of exposure	Internal only; no external access	Potential external access, unconfirmed	Confirmed unauthorised external access
Harm potential	Negligible	Possible reputational impact	Identity theft, financial loss, regulatory harm, aviation safety impact
Duration of exposure	Minutes	Hours	Days or longer

Decision rule: If the overall assessment falls in "High" on any row and "Medium or High" across a majority of rows, treat as Notifiable and proceed to Section 5 immediately. If in doubt, treat as Notifiable.

4.3 Specific Scenarios

Scenario	Notifiable?	Notes
Accidental exposure of a single user's email address to another user	Likely No	Low harm — still document
Firebase misconfiguration exposing database contents to unauthenticated reads	Yes	Highly likely to be Notifiable — immediate containment and notification
Unauthorised access to Captain Adel AI chat logs	Likely Yes	AI chat logs are personal data; may contain sensitive regulatory queries

Scenario	Notifiable?	Notes
Payment data breach at Moyasar (sub-processor)	Yes (report by Moyasar triggers our obligation)	Moyasar holds card data; Fly GACA holds transaction metadata; coordinate with Moyasar
Staff laptop containing local backup lost or stolen	Depends on data	Assess what data was present and whether encrypted
Cloudflare security incident (reported by Cloudflare)	Depends on data accessed	Follow Cloudflare incident report and assess

5. Notification — SDAIA (72-Hour Obligation)

5.1 Deadline

PDPL Art. 20 requires notification to SDAIA within **72 hours** of Fly GACA becoming aware of a Notifiable Breach. The 72-hour clock runs from the time of discovery (Step 4, Section 3.2).

5.2 Timeline and Actions

Hour	Action	Owner
H+0	Discovery confirmed; evidence preserved; initial containment begun	Discoverer / DPO
H+0 to H+4	Severity assessment completed (Section 4)	DPO
H+4 to H+12	If Notifiable: preliminary notification to SDAIA submitted (may be partial — see Section 5.4)	DPO
H+12 to H+48	Full investigation conducted; additional information gathered	DPO + technical support
H+48 to H+72	Full SDAIA notification submitted (updated or supplementary if preliminary was filed)	DPO
H+72+	SDAIA ongoing engagement; data subject notification (if required); recovery and remediation	DPO

5.3 SDAIA Notification Channel

[Note for lawyer: Confirm the current SDAIA breach notification channel — SDAIA portal, email address, or prescribed form — and update this section before this procedure is finalised. As of drafting, SDAIA has announced a breach notification mechanism; counsel should confirm the live submission method.]

Pending confirmation: prepare notification for submission to:

- **SDAIA official notification channel:** [TO BE CONFIRMED WITH LAWYER — insert current SDAIA breach notification portal/address]

- **Backup contact:** National Cybersecurity Authority (NCA) if the breach has cybersecurity dimensions requiring NCA notification

5.4 Content of SDAIA Notification

The notification to SDAIA must include (to the extent known):

1. Date and time the breach was discovered
2. Nature of the breach (unauthorised access / disclosure / alteration / destruction)
3. Categories of personal data affected
4. Approximate number of data subjects affected (or best estimate)
5. Nature of the likely harm to data subjects
6. Measures already taken to contain and mitigate the breach
7. Measures planned to prevent recurrence
8. Contact details of the DPO or responsible officer

If not all information is available within 72 hours, file a preliminary notification and supplement it as quickly as possible. Do not delay filing past 72 hours while waiting for complete information.

5.5 SDAIA Follow-Up

Following the initial notification, SDAIA may request further information or issue directions. All SDAIA communications will be handled directly by the DPO and logged in the Incident Register (Section 8).

6. Notification — Affected Data Subjects

6.1 Obligation

PDPL may require notification to affected data subjects in certain circumstances. [Counsel: please confirm the current data-subject notification obligation under PDPL Art. 20 Implementing Regulations — in particular: (a) whether it is triggered by the same "serious harm" threshold; (b) the required timeframe; (c) the required content.]

6.2 Draft Notification Template

Where data subject notification is required, the following template will be adapted for the specific incident:

Subject: Important Notice About Your Fly GACA Account — Security Incident

We are writing to inform you of a security incident that may have affected your personal information held with Fly GACA.

What happened: [Plain-language description of the incident — e.g., "On [date], we discovered that [describe the incident in plain terms]. We contained the incident on [date]."]

What information was involved: [List the categories of personal data affected — e.g., name, email address, study progress data. Do not over-include or speculate.]

What we have done: [Describe containment and remediation measures.]

What you should do: [Specific, practical steps — e.g., "We recommend you change your Fly GACA password immediately. If you use the same password elsewhere, change it on those services too." / "Monitor your email for suspicious messages."]

Contact us: If you have questions about this incident or want to exercise your data rights under the Personal Data Protection Law, contact us at: privacy@flygaca.com

We sincerely apologise for this incident. We take the security of your data seriously and are committed to preventing recurrence.

Fly GACA Team

6.3 Notification Channels

For registered account holders: email notification to the registered email address. For non-account users (if applicable): prominent notice on the website.

7. Sub-Processor Incidents

7.1 Receiving a Sub-Processor Notification

If a sub-processor (Google Firebase, Cloudflare, Moyasar) reports a security incident affecting Fly GACA's data:

- Immediately assess whether Fly GACA's data and data subjects are affected
- Obtain the sub-processor's incident report
- Proceed through Sections 3–6 of this Procedure as if the incident were internally discovered
- The 72-hour clock runs from the time Fly GACA receives the sub-processor's notification

7.2 B2B — Academy Customer Notification

Where a Security Incident affects personal data processed on behalf of an Academy customer (under a B2B Data Processing Agreement), notify the Academy customer (as Controller) within **48 hours** in accordance with Section 6.1 of the relevant DPA. The Controller is then responsible for its own SDAIA notification as required.

8. Incident Register and Post-Incident Review

8.1 Incident Register

The DPO will maintain a written record of every Security Incident, regardless of whether it is Notifiable. For each incident, the register records:

- Date and time of discovery
- Date and time of containment
- Nature of the incident
- Data affected (categories and number of records)
- Data subjects affected (approximate number)
- Whether Notifiable — and if so, SDAIA notification date and reference
- Whether data subjects were notified
- Remediation actions taken
- Root cause (once established)
- Lessons learned and preventive measures implemented

This register is an internal document maintained at 02-legal/ or equivalent secure location. It will be made available to SDAIA on request.

8.2 Post-Incident Review

Within 30 days of containing a Notifiable Breach, the DPO will conduct a post-incident review to:

- Confirm root cause
- Assess adequacy of response
- Identify preventive measures
- Update this Procedure, the Information Security Policy (04-compliance-ksa/), and technical controls as needed

9. Training and Awareness

All team members with access to personal data will be briefed on:

- How to recognise a potential Security Incident

- The immediate reporting obligation (Section 3.2)
- The contact details for the DPO (privacy@flygaca.com / security@flygaca.com)

This Procedure will be reviewed annually and updated to reflect changes in PDPL Implementing Regulations, SDAIA guidance, or the Fly GACA platform.

10. Related Documents

Document	Location
Information Security Policy	04-compliance-ksa/information-security-policy.docx
PDPL Compliance Programme & DPIA	04-compliance-ksa/pdpl-compliance-program-and-dpia.docx
Sub-Processor Register	04-compliance-ksa/sub-processor-list-and-dpa-register.docx
B2B Data Processing Agreement	02-legal/b2b-data-processing-agreement-draft-2026-06-14.md
Privacy Notice (Full Stage)	02-legal/privacy-notice-full-stage-draft-2026-06-14.md
SECURITY.md (responsible disclosure)	01-governance/SECURITY.md

DRAFT 1.0 — 2026-06-14. Internal document. Pending Saudi legal counsel review. Priority: This procedure must be finalised and SDAIA notification channel confirmed before account launch. The 72-hour clock is a hard statutory deadline with no grace period.